

IPv4

32 bits ; 8 bits octet ; separated by dot
each octet $\Rightarrow$ 0 to 255

IPv6

128 bits ; 8 groups of hexadecimal digits ;
each group 16 bits $\Rightarrow$ 8 groups
separated by colons

IPv4

manual config / DHCP
no built-in security

IPv6

built-in features $\Rightarrow$ data auth & encryption

IPv4

Class A $\Rightarrow$ 1.0.0.0 to 126.255.255.255

Class B $\Rightarrow$ 128.0.0.0 to 191.255.255.255

Class C $\Rightarrow$ 192.0.0.0 to 223.255.255.255

Class D $\Rightarrow$ 224.0.0.0 to 239.255.255.255

Class E $\Rightarrow$ 240.0.0.0 to 254.255.255.255

BASICS OF NETWORKING

Computer Networks → collection of interconnected devices that share resources & info
→ connects autonomous computers

Local Area Network (LAN)

- in small geographic locations
- Room/Building/Campus

Metropolitan Area Network (MAN)

- in city
- connects multiple LANs
- larger than LAN, small than WAN

Wide Area Network (WAN)

- spread geographically
- Country
- connects multiple MANs

Applications of Network

Resource Sharing, Information sharing
Communication, Distributed Computing

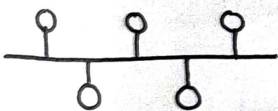
Network Topology

- defines way in which devices are connected
- describes layout of wire & devices as well as the paths used

Network Topology

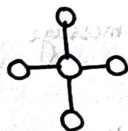
Bus Topology

- Devices connected by one single cable



Star Topology

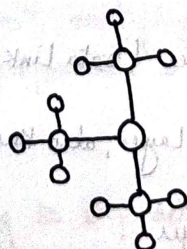
- commonly used architecture in LANs



- Devices connected to single hub
- Hub → Central Node

Tree Topology

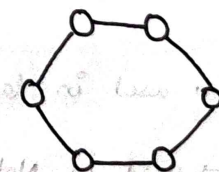
- extended star topology
- significantly reduces traffic on the wires by sending packets only to the wires of host computer



- Hierarchical flow of data

Ring Topology

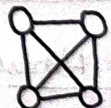
- frame travels around ring stopping at each node.
- frame continues around destination node is found



- Ring connecting devices to exactly 2 neighbor devices

Mesh Topology

- connects all devices to each other for redundancy & fault tolerance
- expensive & difficult
- commonly used in WANs to interconnect LANs



Protocol → rule that defines how data is formatted & processed on network

Networking Media → means by which signals/data is shared among devices

↳ cables/wireless

TCP/IP MODEL → simpler model

→ collection of network protocols & organisation of these protocols in different layers

Application → closest to user, manages data formatting, encryption & session mgmt
bridge b/w software & lower layers; HTTP, FTP, SMTP & DNS
(files) (emails)

Transport → data is sent correctly
checks if the data is received correctly; TCP & UDP

Network → finding best path for data to travel, traffic controller, packet forwarding & fragmentation
uses IP to give every device unique no.

Network Access → physical connection b/w devices
uses MAC address to identify devices

OSI MODEL

Physical Layer → movement of individual bits from one node to next node

Data Link Layer → Node-to-Node delivery of data

Network Layer → responsible for delivery of packets from source to destination host

Transport Layer → delivery of message from one process to another, error recovery

Session Layer → dialog control and synchronization; manage sessions (create & terminate)

Presentation Layer → translation, compression & encryption of message

Application Layer → provides services to user, access to network resources

ADDRESSING

Physical Address → used in last layer (Data Link/Physical) of TCP/IP

Logical Address → used in Network Layer, also known as IP address

Port Address → used in Transport Layer

Specific Address → used in Application Layer

Connecting Devices

Networking

Repeaters

- operates only Physical layer
- allows to extend physical length of network

Hubs

• connect multiple devices
• central point for data transmission

- extend range of routers
- multiple devices can be connected to LAN

Switches

- connects multiple devices in network
- facilitates data communication by filtering data packets based on destination address

Bridges

- operates in both Physical & Data-Link layer
- divides large network into smaller segments

• Simple Bridge - No complex functionality

• Learning Bridge - Have cache records

• Multipoint Bridges - connect multiple segments

Inter-Networking

Routers

- operates in Physical, Data Link & Network Layer.
- Relay packets among interconnected devices

• Chooses least-cost pathway

• Dynamic Routing - take decision basis real-time situation

• Packet Lifetime - time-to-live (TTL)

• Communication Negotiation - decides sender, receiver

Gateways

- operates in all layers
- Protocol conversion

Intrusion → Attempt to break into or misuse system

Perimeter Devices

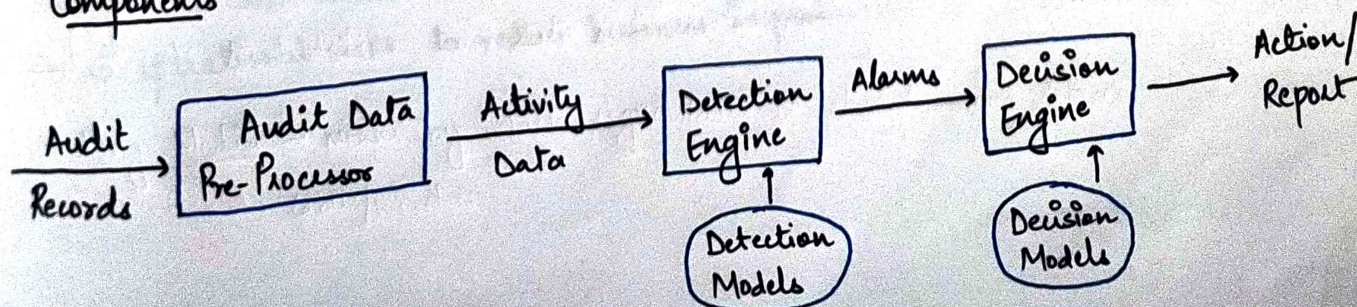
• Intrusion Detection System

monitor events occurring in system/network; analyzing for signs of possible incidents, which violates computer security protocols/standard security practices.

• Intrusion Prevention System

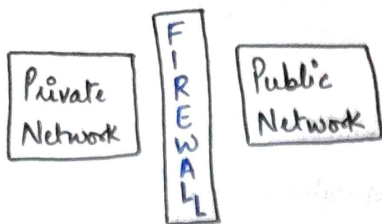
process of performing IDS & attempting to stop detected incidents

Components



• Firewalls

→ collection of security measures designed to prevent unauthorised electronic access to network system



Accept → allow traffic

Reject → block traffic with unreachable error reply

Drop → block traffic with no reply

→ monitor, filter & control incoming/outgoing network traffic based on predefined rules
↓
firewall policies

→ Advantages

- Access Control → prevent unauthorized access based on predefined rules
- Traffic Monitoring → identify patterns in network traffic
- Threat Prevention → block malicious traffic
- Logging → logs for forensic analysis
- Reduce the Attack surface

→ Disadvantages

- Limited Level Protection → cannot inspect application specific threats
- Maintenance → regular updates & rule mgmt
- Complex → requires expertise to configure & maintain
- Impact on Performance → increase latency

→ Types

- Network Firewalls
- Cloud-Based Firewalls
- Proxy Firewalls
- Packet Filtering Firewalls
- Stateful Inspection

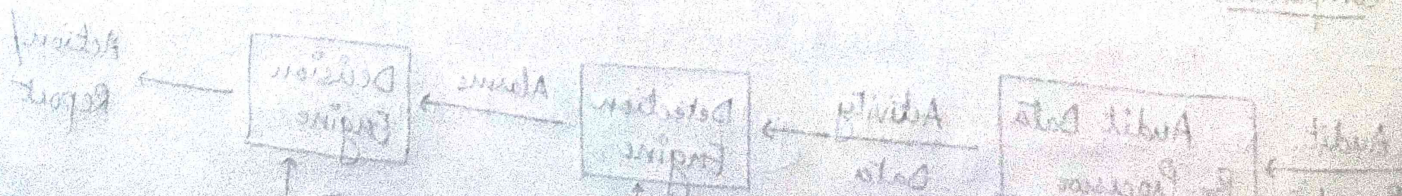
- Hardware
- Software

→ Working

- examines data packets using predefined rules
- makes decision (Allow, Reject & Block)
- records blocked traffic for further review
- sends alert if major threats is detected

→ Need for Firewall

- Preventing unauth access
- Block malicious traffic
- Protect Sensitive Info
- Controlling Network usage



• Network Operations Center (NOC)

- responsible for ensuring corporate network infrastructure is capable of meeting business needs
- optimizes & troubleshoots corporate network
- Responsibilities
 - Network installation & mgmt
 - Data Access & Availability monitoring
 - Server maintenance & optimization

• Security Operations Center (SOC)

- protecting org against cyber attacks
- hardening assets to prevent attacks
- perform incident detection & response
- protect networks & overall infrastructure by security threat detection/prevention & incident response.
- Responsibilities
 - Vulnerability scanning & assessment
 - Threat Detection & Analysis
 - Incident Response & Recovery

Difference b/w NOC & SOC

- NOC
- Network Performance & Availability
 - IT infra, Software & Hardware (Scope of work)
 - consistent monitoring & optimization
 - Incident Types: failures, power outages, etc
 - Service restoration & performance

- SOC
- Security Threats & Incident Response
 - Security infra & threat landscape
 - comprehensive investigation & threat hunting
 - Incident Types: Cyberattacks, Breaches, etc
 - Threat containment & forensic analysis

Similarities b/w NOC & SOC

- Continuous monitoring of systems & network activities
- Similar tech stack: Firewalls, IDS & IPS
- 24/7 operations
- Analyze network traffic
- Reduce operational risks, to reduce business impact

Objectives of NOC

- ensure high availability, reliability & performance of IT infra (devices, servers)
- monitoring & incident response for network issues, system issues
- minimize downtime of network resources

Objectives of SOC

- maintain security of org ⇒ analyzing, detecting & resolving cyber threats
- monitoring for anomalies/malicious activities
- prevent data breaches
- minimize impact from attacks

Difference b/w IDS & IPS

IDS

Advantages

- Monitor network traffic
- valuable for forensic analysis
- helps in meeting regulatory & audit requirements
- operates passively, does not affect network traffic
- enables historic analysis for trend analysis

Disadvantages

- only alerts
- manual intervention is required to detect threats
- cannot real-time attacks
- limited effectiveness

IPS

Advantages

- blocks attacks in real-time
- stops malicious activities
- prevents data breach
- responds through automatic threat blocking

Disadvantages

- may block legitimate traffic
- requires more computing than IDS
- complex configuration
- can introduce latency in network
- struggles against Zero-Day exploits

- Security Information & Event Management (SIEM)
- comprehensive soln combines Security Info Mgmt & Security Event Mgmt → real time analysis of security alerts generated by applications & network hardware
- Centralized platform for collecting & analyzing security data

Functions of SIEM

- Collects logs data from various applications & network
- Real-Time monitoring
- Triggers alerts

SERVERS

DOMAIN NAME SYSTEM (DNS)

- translates human-readable domain names into machine readable IP addresses

Stepwise working of DNS

- ① User enters website domain in browser
Request is checked local DNS cache of browser/system
- ② Not found locally → sent to DNS resolver (managed by Service Provider)
- ③ Resolver contacts different DNS servers to convert domain name to IP Address

Types of DNS Servers

- DNS Resolver → first POC for DNS queries
checks local cache then proceeds to other servers if necessary
- Root Name Server → knows about all TLD servers
directs queries to respective TLDs
- Top Level Domain Name Server (TLD) → manages domains for every extension
provides info about nameservers for specific domains
- Authoritative Name Server → holds actual DNS records for domain & its IP add

DNS Query Flow

- User enter domain name
- local cache checked
- query sent to DNS Resolver
- Resolver queries Root Name Server
- RNS refers to appropriate TLD Server
- TLD server points to authoritative server
- AS returns IP to Resolver
- Resolver provides result to user's computer

Importance of DNS

- makes internet user friendly by converting domain to IP address
- offers fault tolerance & redundancy

TOP LEVEL DOMAIN SERVER (TLD)

- type of DNS server
- stores & manages info about domain names under particular domain extension
- direct queries to respective authoritative name server

Eg: .com TLD Server manages info about all websites ending in .com

Importance of TLD

- DNS queries are routed quickly & correctly
- geographically distributed & high fault tolerance

PROXY SERVER

- intermediate that acts as gateway b/w user's device & internet or b/w 2 devices
- it intercepts user request & forwards it on its behalf
- enhances privacy, security & performance
- masks user IP address

Functions of Proxy Server

- hides user's real IP address
- acts as access control based on set policies
- cache frequent accessed content to reduce loading time
- access content restricted in the region → proxy server of different location

MAIL SERVER

- facilitates sending, receiving & storage of email
- hub for mail communication
- manages how emails are routed b/w sender & recipient

Mail Transfer Agent (MTA) → receives incoming mails & forwards them to delivery

- routes email from sender's mail server to recipient's mail server
- protocols like Simple Mail Transfer Protocol (SMTP)

Mail Delivery Agent (MDA)

- receives email from MTA
- stores in recipient's mailbox

APPLICATION SERVER

- hosts applications/software that delivers business appln through communication protocol
- centralized environment for running, managing & delivering web-based applns.
- middleman b/w client interface & backend servers

DYNAMIC HOST CONFIGURATION

PROTOCOL (DHCP)

- works on client-server model
- manages pool of IP addresses & configuration data → DHCP Server
- requests info when connected to internet → DHCP Client
 - ↳ subnet mask,
 - IP address, etc
- assigns IP addresses & network parameters to devices on network
- this info comes from centralized DHCP Server

DORA Process → Discover, Offer, Request, Acknowledge

- DHCP Discover → device broadcasts discover message
- DHCP Offer → DHCP server receives discover message & responds with offer msg
 - msg contains available IP address & network configurations
- DHCP Request → client selects one of the offered configurations & broadcasts request msg
 - msg contains DHCP server identifier
 - broadcasting ensures all DHCP server are informed of the selection
- DHCP Acknowledge → selected DHCP server responds with ACK msg, confirming configuration assignments
 - server records these details in its DB

DHCP Lease

- DHCP assigns IP addresses for specific time periods called Leases
- prevents unused addresses from permanently be used

Advantages

- eliminates manual assignment of IP
- centralized mgmt for configuration changes
- prevents IP conflicts

Eg: corporate network range 192.168.1.0/24

New device joins network

IP Conflicts

- 2 or more devices same IP on same network
- causes routing confusion
- connectivity problems
- manual assignment causes this

(DHCP) PROTOCOL

INTERNET SECURITY

- comprehensive protection of data, systems & network from threat that comes through internet
- ensure CIA Triad
 - ↳ Confidentiality $\Rightarrow$ info is private & accessible to authorized
 - Integrity $\Rightarrow$ info cannot be changed/tampered
 - Availability $\Rightarrow$ info is available to authorized when needed

OSI Security Architecture

ITU-T X.800 $\longrightarrow$ defines Security Attack, Security Mechanism & Security Service
↳ International

Telecommunications Union -
Telecommunications Standardized
Sector

Security Attack $\rightarrow$ action that compromises security of info

Security Mechanism $\rightarrow$ process designed to detect, prevent or recover from security attack

Security Service $\rightarrow$ enhances security of systems & info transfers

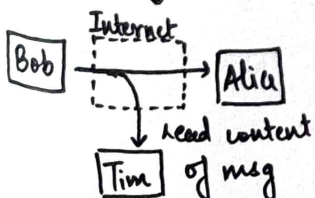
SECURITY ATTACK

Any action that compromises the security of information owned by organization

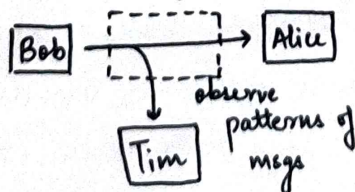
Passive Attacks

- $\rightarrow$ attempt to learn/use info from system while not affecting system resources
- $\rightarrow$ Goal $\Rightarrow$ obtain info that is transferred
- $\rightarrow$ Eg: Eavesdropping, Monitoring Traffic

Release of Msg
Contents



Traffic Analysis



Active Attacks

- $\rightarrow$ attempt to alter system resources, modify system data
- $\rightarrow$ Masquerade - entity pretends to be diff entity. compromises authentication
- $\rightarrow$ Replay - unauth repetition of prev msg. Attacker capture data & retransmit to gain unauth access
- $\rightarrow$ Modification of msgs - unauth alteration of data during transmission
- $\rightarrow$ Denial of Service - prevention of auth users to access resources by degrading system performance

$\rightarrow$ Difficult to detect, as no intervention is done

SECURITY MECHANISM

Process to prevent, detect or recover from security attack by implementing one/more security services

Specific Mechanisms

- Encipherment
- Digital Signature
- Access Control
- Data Integrity
- Authentication Exchange
- Traffic Padding
- Routing Control
- Notarization

- Incorporated into specific layer of OSI architecture

Pervasive Mechanisms

- Trusted Functionality
- Security Label
- Event Detection
- Security Audit Trail
- Security Recovery

→ not specific to any particular OSI layer

SECURITY SERVICES

Service provided by Protocol Layer of communicating open systems, which ensures security of system/data transfer $\Rightarrow$ X.800

Processing Service provided by system to give specific protection to system resources $\Rightarrow$ RFC 2828

Categories

Authentication

- assurance that communicating entity is the one it claims to be

Access Control

- prevention of unauthorized use of resources

Data Confidentiality

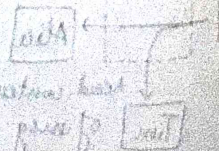
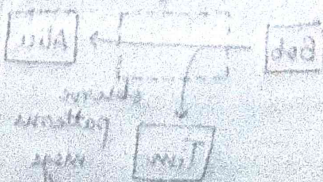
- protection of data from unauthorized disclosure

Data Integrity

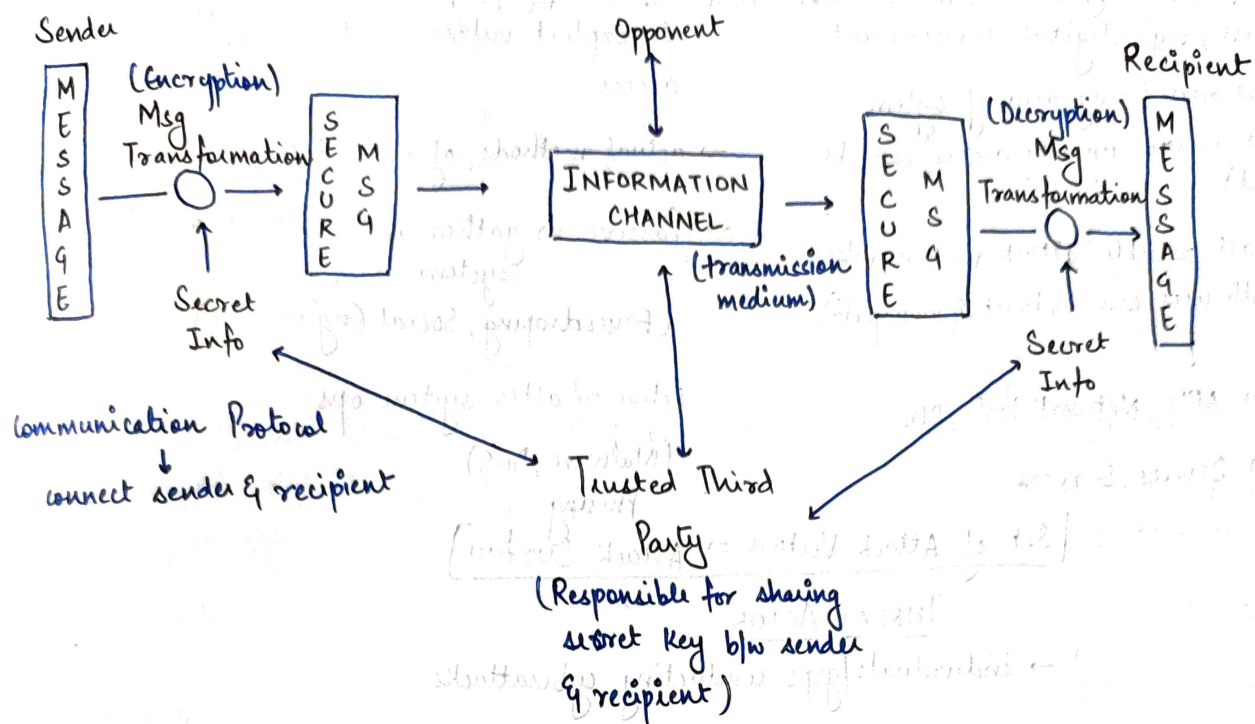
- assurance that data received is exactly as sent by sender (auth entity)

Non-Repudiation

- protection against denial by one of the entities involved in communication



MODEL FOR NETWORK SECURITY



Tasks while designing Security Model :

- Design algorithm for performing message transformation ⇒ difficult for opponent to crack
- generate secret info ⇒ used in algo
- develop methods for sharing secret info
- specify protocol to be used by both entities which uses transformation algo & security info

Network Security Model ⇒ Security designed to prevent opponent from causing threat while sharing info through network

ATTACK SURFACE

- All potential entry points & vulnerabilities that exist org's digital environment
- Entire external-facing area of system
(All points where unauth access can be achieved)
- Sum of all possible attack vectors, where an unauth user can extract & manipulate data
- Digital ⇒ APIs, Network Ports, DBs
Physical ⇒ Devices, Servers

ATTACK VECTOR

- specific method/technique used by attackers to exploit vulnerabilities & gain unauth access
- actual methods of exploitation
- Passive ⇒ gather info without affecting system
(Eavesdropping, Social Engineering)
- Active ⇒ alter system ops
(Malware, DoS)
Phishing

[Set of Attack Vectors ⇒ Attack Surface]

THREAT ACTOR

- individuals/groups conducting cyberattacks

THREAT VECTOR

- combination of source of threat & methods used
- represent pathways through which attack happen

MAC Address

- 48 bit address at Data Link layer
- physical address for device identification within local network
- 6 groups of hexadecimal
00:1A:2B:3C:4D:5E
- unique for all devices within same network

Address Resolution Protocol

- bridge b/w Network (IP) & Data Link (MAC) layer
- 32 bit IP ⇒ 48 bit MAC for device communication
- Each Node has ARP Table
↳ mapping of IP & MAC
- works on broadcasting requests & caching responses

Process:

- Device broadcast msg who has IP_A tell IP_B
- Device with IP_A or ARP server receives msg & broadcasts response IP_A is MAC_A
- Requestor's IP is included in link header
- Requestor's table is updated

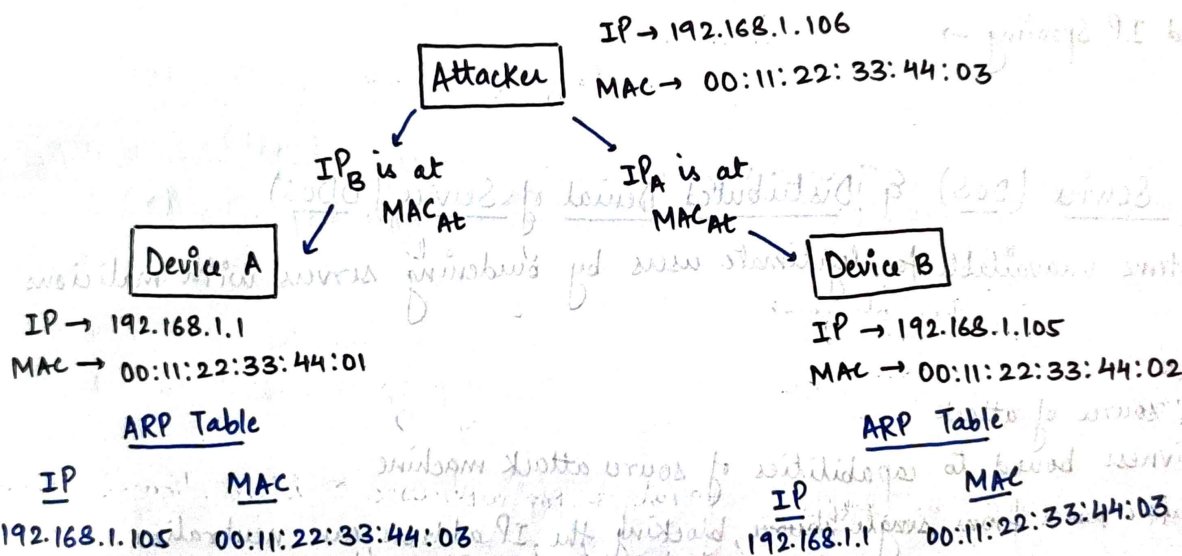
TYPES OF ATTACKS

ARP Poisoning (ARP Spoofing)

- exploits stateless nature of ARP $\Rightarrow$ Man-in-middle attack
- ARP lacks authentication mechanism
- ARP caches all ARP replies regardless of if they were requested or not

Mechanism

- Attacker send fake ARP msgs using its MAC & legitimate user's IP
- Target device updates the ARP Table with Attacker's MAC
- All traffic will be redirected to Attacker
- Attacker can eavesdrop, modify msg or disrupt network



TCP Session Hijacking

- taking control of established TCP connection b/w 2 devices
- TCP connection → sequence no & acknowledge no; in each packet
- 2 devices negotiate the seq. & ack no.s → used to setup TCP
- No size of SEQ & ACK $\Rightarrow 2^{32}$
 - difficult to guess seq & ack no
 - hard to hijack established TCP

Mechanism

- Attacker sniff active TCP packets → guess seq & ack
- Attacker inject packet with correct seq & ack no.s with spoofed IP, taking control of session

Coordinated IP Spoofing →

Denial of Service (DoS) & Distributed Denial of Service (DDoS)

- make systems unavailable for legitimate users by burdening servers with malicious traffic
- DoS Attack
 - Single source of attack
 - effectiveness bound to capabilities of source attack machine
 - as traffic comes from single source, blocking the IP address can neutralize
- DDoS Attack
 - Multiple sources of attack $\Rightarrow$ use of botnets
 - effective attack as servers can be easily burdened
 - complex to defend

Smurf Attack

- Type of DDoS
- exploits ICMP to increase network traffic
- uses broadcast networks to multiply impact of malicious packets

SYN Flooding Attack

TCP Three-way Handshake

• Process to establish duplex connection b/w client & server

Steps:

- Client sends SYN (initial request)
- Server sends SYN-ACK (Server's Agreement & Acknowledgment)
- Client sends ACK (Final Acknowledgment)

Client

Server

SYN
(seq=x)

SYN-ACK

seq=y
ack=x+1

ACK

ack=y+1
seq=ack+1

Classification of Cryptosystems

is primarily how
key is generated

Block Cipher
Stream Cipher

≠ key

symmetric / single-key
asymmetric / two-key

type of operation
used

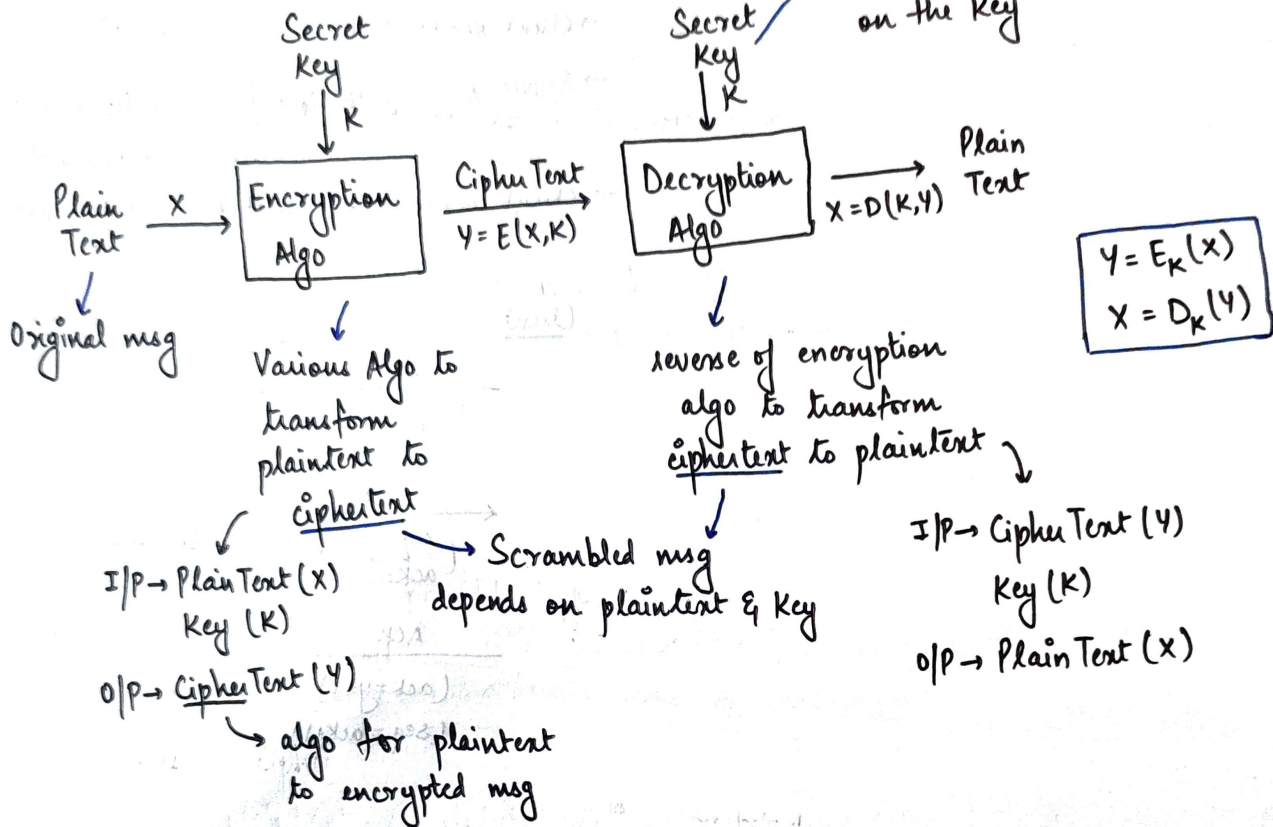
substitution
transposition

substitution
(acknowledgment)

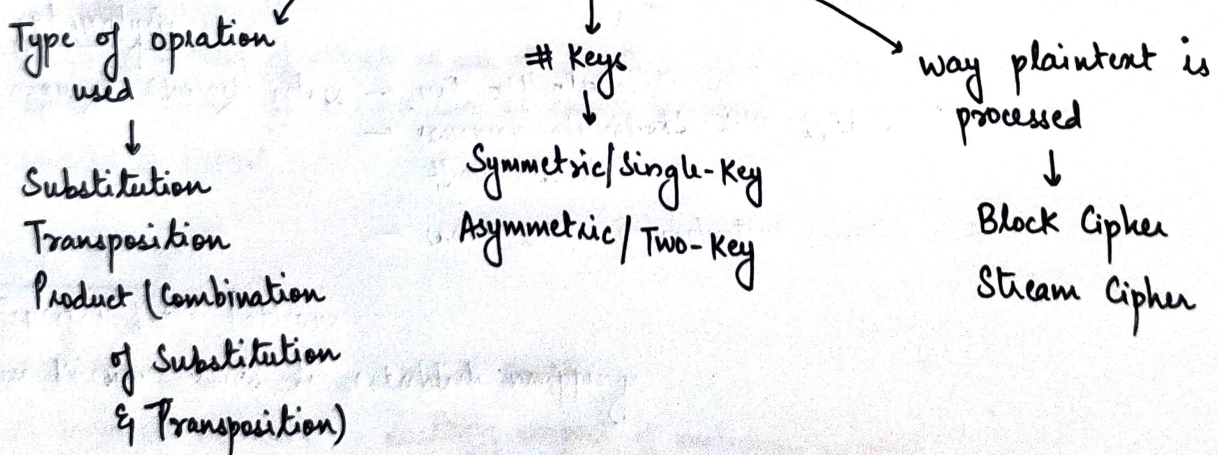
CRYPTOGRAPHY

SYMMETRIC ENCRYPTION

Secret-Key / Single Key encryption ; sender & receiver share common Key
 i/p to algo ; encryption depends on the Key



Classification of Cryptography



CRYPTANALYSIS

- Process of attempting to identify plaintext/key
- Strategy used depends on encryption algo & info available

Type of Attack

Info with Cryptanalyst

Ciphertext Only

(Most difficult) (easiest to defend)

Encryption Algo, Ciphertext to decrypt

Known Plaintext

Encryption Algo, Ciphertext to decrypt, one/more plaintext-ciphertext formed

Chosen Plaintext

Encryption Algo, Ciphertext, plaintext msg chosen with its corresponding ciphertext

Chosen Ciphertext
(Less common)

Encryption Algo, Ciphertext, ciphertext chosen along with decrypted msg

Chosen Text
(Less common)

Encryption Algo, Ciphertext, plaintext chosen along with its ciphertext, ciphertext chosen along with its decrypted msg

Ciphertext Only ⇒ Most difficult attack
easiest to defend, very less info known

Encryption Algo is Computational Secure → cost of breaking cipher exceeds value of encrypted msg
→ Time required to break cipher > Lifetime of info

Encryption Algo is unconditionally secure → no matter compute power, cipher cannot be broken
→ ciphertext has insufficient info

SUBSTITUTION CIPHER

Any char of plaintext from given set of chars is substituted by some other character from same set of chars

Caesar Cipher

- simplest
- each letter in plaintext is shifted by fixed no of positions
- Named after Julius Caesar

$$E(x) = (x+n) \bmod 26 \quad \rightarrow \quad n \Rightarrow \text{shift of letters}$$

$$D(x) = (x-n) \bmod 26 \quad \rightarrow \quad x \Rightarrow \text{numerical no of letter}$$

- Usually $n=3$

Cryptanalysis

- Brute Force $\Rightarrow$ only 26 possible keys
- Known plaintext attack

Monoalphabetic Cipher

- each letter in plaintext substituted with corresponding letter in cipher set
- pattern is random
- every letter has diff unique key

Cryptanalysis

- Language Characteristics
 - not all alphabets used equally
 - common alphabets like E, T, A, O, I, N are used more than others
 - count letters in ciphertext ; replace with high-freq letters
- Repeated Letter Patterns
- use known words to establish mappings

Playfair Cipher

- encrypts pairs of letters
- 5×5 key matrix
- Rules:
 - same row $\Rightarrow$ replace letter with right letter
 - same column $\Rightarrow$ replace letter with below letter
 - diff row & column $\Rightarrow$ draw rectangle $\Rightarrow$ replace letter with opposite corner letter
 - plaintext converted to digraphs
 - letter repeated $\Rightarrow$ insert filler 'x'
- commonly I & J are treated same
 - $\hookrightarrow$ change according to key & plaintext (M & N, X & Y, etc)

Cryptanalysis

- # digrams = $26 \times 26 = 676$
- Known plaintext attack $\Rightarrow$ plaintext-ciphertext pairs known, can create key matrix
- digraph & its reverse decrypt to same pattern (decryption will also be reverse)